

Assignment 2: Authentication Methods

Information Security

July 15, 2026

A2: Authentication Methods

Question 1 — Replacing Passwords with Multi-Factor Authentication (MFA)

A university plans to replace password-based login with multi-factor authentication (MFA).

1.1 Advantages and challenges of implementing MFA

Multi-factor authentication (MFA) requires a user to prove their identity using two or more independent factors: something you **know** (password/PIN), something you **have** (phone, token, smart card), and something you **are** (fingerprint, face).

Advantages:

- **Much stronger security.** Even if a password is stolen or guessed, the attacker still cannot log in without the second factor.
- **Protection against common attacks.** MFA blocks phishing, credential stuffing, and password-reuse attacks that plague single-password systems.
- **Better protection of sensitive data.** University systems hold grades, research, and personal records, so the extra layer reduces the impact of a breach.
- **Regulatory and reputational benefit.** MFA helps meet data-protection requirements and increases trust among students and staff.

Challenges:

- **User inconvenience.** Extra steps can frustrate thousands of students and faculty and increase login time.
- **Cost and infrastructure.** Deploying tokens, apps, or biometric readers across a large university needs budget and maintenance.
- **Device dependence.** Users may lose their phone or token, requiring account-recovery and help-desk support.
- **Support and training.** Many users are non-technical, so onboarding, documentation, and support desks are essential.
- **Coverage gaps.** Some legacy systems may not support MFA and must be upgraded or replaced.

1.2 Suitable combination of authentication factors

Recommended combination: password (something you know) + authenticator-app one-time code or push notification (something you have).

Justification:

- **Balances security and usability.** It adds a strong second factor without needing expensive hardware for every user.
 - **Uses devices students already own.** Almost everyone has a smartphone, so an app like Google/Microsoft Authenticator or push approval is low-cost.
 - **Resists phishing better than SMS.** App-based codes and push prompts avoid SIM-swapping and SMS-interception weaknesses.
 - **Scalable and easy to recover.** Backup codes and self-service recovery reduce help-desk load.
 - **Optional third factor for high-risk access.** Add biometrics or a hardware key (e.g., FIDO2/YubiKey) for administrators and sensitive systems.
-

Question 2 — Smart Card-Based Authentication in a Government System

A government system uses smart cards for authentication.

2.1 How smart card-based authentication works

A **smart card** is a plastic card with an embedded microchip that securely stores credentials such as a private key or digital certificate.

- **The secret never leaves the card.** The private key is stored inside the chip and is used for cryptographic operations without being exposed.
- **The user proves possession.** The card is inserted into a reader (or tapped for contactless cards) to prove “something you have.”
- **A PIN unlocks the card.** The user enters a PIN, adding “something you know,” so a stolen card alone is not enough (two-factor).
- **Challenge–response verifies identity.** The system sends a challenge; the card signs or encrypts it with its internal private key, and the server verifies it using the matching public key/certificate — without the secret ever being transmitted.
- **PKI backs the trust.** Certificates issued by a trusted authority link the card to a verified identity, enabling secure login and digital signatures.

2.2 Effectiveness compared to password-based systems

Smart cards are significantly more secure than passwords:

- **Two-factor by design.** They combine the physical card with a PIN, whereas a password is only one factor.
- **Resistant to theft over the network.** The private key never travels, so it cannot be phished, sniffed, or stolen from a server database.
- **Strong cryptography.** Authentication relies on public-key cryptography and certificates, far stronger than a memorized secret.

- **Harder to share or copy.** A physical chip is much harder to duplicate than a password that can be written down or reused.

Limitations to consider:

- **Needs hardware.** Card readers and issuance infrastructure add cost and complexity.
- **Loss or damage.** A lost, forgotten, or broken card blocks access until replaced.
- **Physical theft risk.** If the PIN is weak or exposed, a stolen card could be misused — so PIN protection remains important.

Conclusion: For a government system, smart cards offer far better security than passwords, provided card issuance, revocation, and PIN policies are managed well.

Question 3 — Biometric Authentication for Employee Access

An organization introduces biometric authentication (fingerprint/face recognition) for employee access.

3.1 Security benefits and privacy concerns of biometrics

Security benefits:

- **Uniquely tied to the person.** Biometrics are “something you are,” so they cannot be forgotten, guessed, or easily shared like passwords.
- **Convenient and fast.** Employees authenticate with a fingerprint or face scan in seconds, improving user experience.
- **Hard to transfer.** Unlike cards or passwords, a biometric cannot simply be handed to a colleague, reducing credential sharing.
- **Strong when combined.** Used alongside a card or PIN, biometrics create a powerful multi-factor system.

Privacy concerns:

- **Permanent and irreplaceable.** If biometric data is stolen, you cannot “reset” your fingerprint or face the way you reset a password.
- **Sensitive personal data.** Biometric records are highly personal and, if leaked, can enable identity theft or surveillance.
- **Spoofing risks.** Fingerprints and faces can sometimes be faked with molds, photos, or deepfakes without proper liveness detection.
- **Function creep and consent.** Data collected for access could be reused for other purposes (e.g., tracking), raising ethical and legal issues.
- **Legal compliance.** Laws such as GDPR treat biometrics as sensitive data requiring explicit consent and strong protection.

3.2 Recommended safeguards to protect biometric data

- **Never store raw biometrics.** Store only a mathematical template (irreversible representation), not the actual image of the fingerprint or face.
- **Encrypt everything.** Protect templates with strong encryption both in storage and during transmission.

- **Keep data on secure hardware.** Store templates in a secure element or trusted enclave on the device rather than in a central database where possible.
- **Add liveness detection.** Use anti-spoofing checks to ensure a real, live person is present, not a photo or replica.
- **Combine with another factor.** Pair biometrics with a card or PIN so a single compromised factor is not enough.
- **Enforce strict access control and auditing.** Limit who can access biometric data and log all access.
- **Obtain consent and follow the law.** Get informed employee consent, limit data use to its stated purpose, and comply with GDPR and similar regulations.
- **Plan for revocation.** Support cancelable biometrics or fallback methods so a compromised template can be replaced.

Summary: Biometrics greatly improve convenience and security, but because they are permanent and highly sensitive, they must be protected with encryption, templating, liveness detection, and strict privacy safeguards.